

From Breach to Boardroom

UrbanTrail Outfitters

Background

- UrbanTrail Outfitters is a privately held retail chain with 40 stores and an online storefront. All in-store point-of sale (POS) terminals connect to a shared corporate network that also carries employee email and guest Wi-Fi — the POS terminals were never placed on a separate, segmented network.
- Each fall, UrbanTrail hires short-term IT contractors to help configure new POS terminals ahead of the holiday season. Contractor accounts are created quickly to meet the deadline, but there has historically been no formal process for disabling them once a contract ends.
- One such contractor, hired for eight weeks the previous year, was given elevated access to the POS terminal configuration system. His contract ended three months before this incident began.

Incident Response & Compliance Worksheet

Part 1 — Cyber Kill Chain Mapping

Kill Chain Stage	Evidence from the Timeline
1. Reconnaissance	An unknown party discovers the exposed credentials, using an automated tool that routinely scans public code repositories, and finds the contractor's old Urban Trail login credentials in plain text, which is still good.
2. Weaponization	Attacker uses still active account to create false firmware update that configures terminals to read card data directly from terminal during checkout

3. Delivery	The pushing of the firmware
4. Exploitation	When card is swiped or inserted card numbers, expirations, and in some cases CVV are captured
5. Installation	Every few hours small batches of captured data are sent out disguised as routine terminal health check pings, that are timed to stay under the volume that would trigger network alerts
6. Command and Control (C2)	-Does not apply because the attacker's program is sending information, not taking commands in real time, or communicating.
7. Actions on Objectives	Attacker captures (exfiltrates) sensitive card data over many weeks, obtaining card numbers, expiration dates, and some CVV codes as well.

Part 2 — MITRE ATT&CK TTP Table

Attacker Action	Tactic (Why)	Technique (How)	Procedure (What tool)
Scans for public code repositories - automated	Recon for log-in, or access credentials	Scans public code repositories	Automated scanning tool
Small program that reads card data from terminal	To obtain card data for financial gain (probably)	Program reads card data	The configuration by program to read card data
Logs into POS configurations system remotely	To access system to push firmware that installs his program	Attacker logs in with stolen credentials	Logging into POS configuration sys.
Pushed a firmware update that installs the program	Firmware installs his program to POS terminals across 40 stores	Firmware pushes configuration of attacker's program	Firmware update—POS configuration manager
Captured data is sent back in small batches disguised as "health-check" pings	Data theft (card information)	Data sent in small batches under certain threshold to not trigger alerts	Program that was installed with firmware update

Part 3 — Attack Type Classification

PRIMARY ATTACK TYPE

-Malware

JUSTIFICATION (CITE SPECIFIC EVIDENCE)

-Attacker used compromised credentials found in scan to install a program that fed him card data. His program sent him card data in small batches so as not to set off alarms allowing him to stay in the network longer to gather more card number information, most likely for financial gain.

SECONDARY ATTACK TYPE(S), IF ANY, AND WHY

-Possibly an Advanced Persistent Threat (APT) because its goal was data exfiltration, and it was a long term attack (multiple weeks). However, it does not appear to be state sponsored.

Part 4 — Regulatory & Compliance Impact Analysis

Framework	Applies? (Y/N)	Why or Why not - Cite Evidence
HIPPA	No	Does not deal with PHI, or other health information
GDPR	No	No business done in Europe
PCI-DSS	Yes	Card information is processed by this company – data theft of card info.
SOX	No	Not a publicly traded company

IF A FRAMEWORK APPLIES: WHAT DOES IT REQUIRE NEXT?

-PCI-DSS applies to this incident. This company stores and processes card data. They did not implement regular scans, or practice strict access control of the network. Also, they did not have a segmented network. They need to contain and mitigate this breach of data, and implement network segmentation of POS terminals, employee email, and guest Wi-Fi. They need to implement a formal process to decommission contractor access once the contract has ended. They need to implement least privilege, and RBAC. They also need to encrypt their data at rest, and in transit. Implement tokenization, and restrict access to payment systems.

ESTIMATED STAKES

-Based on figures from Lesson 15 this company's potential fallout after 210,000 card numbers were compromised. They would undoubtedly suffer great reputational loss of consumer trust. It's hard to actually calculate a hard number of financial losses because of this incident. Yes they will probably lose business, but consumers may really like their products, and they could bounce back. They could also lose a lot of business and go into bankruptcy. I think they would lose millions, but unsure of exactly how much.

Part 5 — Audit & Remediation Plan

Phase	Prompt	Your Plan
Planning	What will you audit? Which systems, policies, or departments are in scope? Who needs to be involved?	Plan to audit company based on PCI-DSS standards, to include access control, POS terminals, card data storage, use of encryption, network segmentation, EDR, DLP, RBAC, anti-malware/virus scans, MFA. This will involve the company's IT contractor companies, along with administration of Urban Trail Outfitters.
Execution	What evidence will you gather? What controls will you test?	Hire third party external auditor with known experience to audit company using PCI-DSS as a standard to achieve. Need to test a company's resilience to malware, phishing, and remote services. Ensure MFA, RBAC, EDR, and DLP are in place and working.
Reporting	What are the key findings? How would you rate their severity (low / medium / high)?	This company should invest in getting another IT contract provider, or heavily invest in an IT team that strives to be compliant with PCI-DSS. There is no segmentation of the network, the IT contractors they used in the past did not do a good job of properly onboarding, or offboarding, card data is not properly secured. No MFA, password hygiene is poor. No active scanning for malware, or viruses. No known security training. All of these rates are high in severity.
Follow-Up	What specific remediation steps need to happen, and how will you verify they were completed?	Start by employing an IT contractor, or provider that can bring company into PCI-DSS, and secure their sensitive

		information (PII, card data), employ MFA, anti-malware/virus scanning, network segmentation, encryption of card data at rest, and in transit. Has an incident response plan, and can manage this year round, not just seasonally. Will verify this with periodic external audits done every quarter.
--	--	--

Part 6 — Security Awareness & Culture Proposal

TRAINING FOCUS

-This breach occurred due to lack of formal de-commissioning process in a nutshell. Once credentials were captured, the attacker installed a program that sent him data, and accomplished this without being noticed for many weeks. The IT company who creates the accounts need more oversight and regulation with this, as they are granting access to systems that contain sensitive card data of customers. They are not using best practices with company data, and network access. Focus of training should be on adhering to policies, and procedures (once created) for company and IT staff to maintain safe handling of customer card data. Currently this company is in violation of PCI-DSS, and needs awareness training of all employees in best security practices. Start with the executive staff of Urban Trail Outfitters, but also disseminate to IT, and other employees of the company.

DELIVERY FORMAT & REINFORCEMENT

-This training should be initially delivered in person. There are so many glaring holes in this company's security posture that it needs a lot of improvement, but over time (with improvement) training could become online for front line employees, and perhaps some simulation for the IT to train for possible future breaches.

ONE CULTURE INITIATIVE

-I propose instituting a "no-blame" culture at this company. The only way to get better is to know what mistakes are being made, and try to improve. This breach occurred due to human error, and was also the result of a culture that did not prioritize cybersecurity as a pillar. This takes time, but initially we want to know about mistakes in order to correct them, thus improving our security posture in the future, and have a culture that is security aware.

Part 7 — Executive Summary & Presentation Outline

Segment	Your notes
What happened	-An attacker gained access through still active elevated credentials of an IT contractor who had done work for the company 3 months prior to this incident whose account was never disabled. The attacker was able to use these credentials to install a program that sent him card data of our customer during a 5 week period over the holidays. A partner bank noticed unusual activity and notified security team.
How it happened	-Recon: Attacker ran an automated scan looking for credentials like this on public repositories. -Weaponization: Malware program that sent card data -Delivery: Remote access into POS configuration system -Exploitation: Pushing of the “firmware update” to terminals (40 locations). -Installation: “Firmware update” installs malware that sends card data in small batches under a certain volume to avoid detection. -Command and Control: None (information was fed to the attacker, he did not have to communicate with it to obtain info, or change anything.) -Actions on Objectives: Customer card data exfiltrated (data theft)
What it means for us	-For us this means a serious overhaul of security measures. Need to become compliant with PCI-DSS as we are currently not, and in violation due to company processing card data. Card data needs to be secured, encrypted, and monitored. Our system needs to be segmented. No need for POS terminals to be on the same system as employee email, or Wi-Fi. Need to create a culture of security minded executives, and employees through training. Implement tools that already exist to monitor our system such as malware/anti-virus scanning, RBAC, MFA, EDR, DLP, log auditing systems, access control, and data encryption. These things need to happen as soon as possible, but the focus should be on becoming compliant with PCI-DSS, and then continue to strengthen our security posture further. Secure card data, and credentials ASAP, but other implementations over time, with auditing every quarter.
What we’re doing about it	-First find a good experienced IT contractor that can assist this company in becoming compliant with PCI-DSS as soon as possible. Perform internal audits at least once a month, and have a third party perform external audits quarterly. Create a culture of reporting mistakes without fear of reprisal, and a culture of security minded individuals – this takes time, but through training and enforcement it can be done. Use this incident as a learning opportunity, and take measures to mitigate the chances of it happening again by investing

	in technology, and programs that educate the workforce on cybersecurity best practices.
--	---